to handle, the harder it becomes to understand who has access to what—and why.

In many modern systems, a user's access can't be determined solely by their job title or inclusion on a list. It may depend on factors such as the time of day, the security posture of their device, their relationship to a specific resource, or whether they meet regulatory or contractual requirements. These factors are dynamic, requiring dynamic models.

The next chapter explores three models: Attribute-Based Access Control (ABAC), Relationship-Based Access Control (ReBAC), and Policy-Based Access Control (PBAC). These approaches offer greater flexibility, expressiveness, and scalability—though at the cost of increased complexity. Together, they establish the foundation for modern, policy-driven authorization systems that can meet the demands of today's applications.

5.4 Summary

- Static authorization models evaluate access based on predefined lists or assignments and are efficient to evaluate at runtime.
- Access Control Lists (ACLs) attach permissions directly to resources, making them simple and transparent but difficult to manage at scale.
- Role-Based Access Control (RBAC) introduces roles as an intermediary, aligning access with organizational structure and improving manageability.
- Both ACLs and RBAC map onto the standard authorization reference architecture, though often with tightly coupled or application-embedded components.
- RBAC supports additional governance features, like separation of duty constraints and role hierarchies, but lacks support for dynamic context.
- Static models remain widely used and appropriate in systems with stable responsibilities and clearly bounded access needs.
- As systems grow more dynamic and complex, static models struggle to adapt, creating a need for more expressive, context-aware approaches.